

Mount Kenya University

Unlocking Infinite Possibilities

NAME : STEPHEN KIMANI

ADMISSION: BSCCS/2024/57444

COURSE : BACHELOR OF SCIENCE IN COMPUTER SCIENCE

UNIT CODE: BIT 4139

UNIT NAME: ETHICAL HACKING AND COUNTERMEASURES

LECTURER: MICHAEL NYORO

SEMESTER /ACADEMIC YEAR: SEMESTER 6

Table of Contents

WEEK 1 - INFORMATION GATHERING (Kenya Red Cross).....	4
Domain Registration Information.....	4
Domain IP Address Resolution.....	4
DNS Information Lookup.....	5
Email and Subdomain Enumeration.....	6
Website Technology Identification.....	6
Reflection.....	7
– SCANNING AND ENUMERATION.....	7
WEEK 2.....	7
Open Port Discovery.....	7
Service Version Detection.....	7
Operating System Detection.....	8
Vulnerability Assessment.....	8
Reflection.....	8
WEEK 3- Vulnerable Environment Setup.....	9
DOCKER INSTALLATION VERIFICATION.....	9
DVWA Container.....	9
Reflection.....	9
WEEK 4 – Web Application Deployment and Configuration.....	10
DVWA Login Interface.....	10
DVWA Database Setup.....	11
DVWA Home Interface.....	12
Reflection.....	12
Week 5 – SQL Injection Testing and Exploitation.....	13
SQL Injection Module.....	13
SQL Injection Test Results.....	13
Retrieval of Additional User Records.....	14
Reflection.....	14
WEEK 6 – VULNERABILITY ASSESSMENT AND SCANNING.....	15
Nikto Installation.....	15
Web Server Vulnerability Scan Using Nikto.....	16
Web Server Header Analysis.....	17
CVE Vulnerability Research.....	17
CVE Number.....	18
Description.....	18
Severity.....	18
Potential Impact.....	18
Mitigation.....	18
Reflection.....	18
WEEK 7.....	19
HTTP REQUEST ANALYSIS.....	19
Cookie Security Analysis.....	20
.....	20

Cross-Site Scripting Testing.....	20
OWASP Top 10 Security Risks.....	21
.....	21
Reflection.....	21

WEEK 1 - INFORMATION GATHERING (Kenya Red Cross)

Domain Registration Information

```
(him@kali)-[~]
$ whois redcross.or.ke
Domain Name: redcross.or.ke
Registry Domain ID: 123096-KENIC
Registrar URL: http://domains.safaricom.co.ke
Updated Date: 2025-11-11T13:42:04Z
Creation Date: 2013-09-17T10:13:01Z
Registry Expiry Date: 2028-09-17T10:13:01Z
Registrar Registration Expiration Date: 2028-09-17T10:13:01Z
Registrar: Safaricom Limited
Registrar Street Address: Safaricom House, P.O. Box 46350 - 001001, Nairobi
Registrar Phone: 0722002222
Registrar Email: ebt-domains@Safaricom.co.ke
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: active https://icann.org/epp#active
Name Server: laura.ns.cloudflare.com
Name Server: tom.ns.cloudflare.com
DNSSEC: unsigned
>>> Last update of WHOIS database: 2026-06-08T11:01:45.783Z <<<

For more information on domain status codes, please visit https://icann.org/epp
```

Figure 1: The WHOIS command retrieved domain registration information for the target organization.

Domain IP Address Resolution

```
(him@kali)-[~]
$ host redcross.or.ke
redcross.or.ke has address 172.67.162.183
redcross.or.ke has address 104.21.81.172
redcross.or.ke has IPv6 address 2606:4700:3033::6815:51ac
redcross.or.ke has IPv6 address 2606:4700:3032::ac43:a2b7
redcross.or.ke mail is handled by 0 redcross-or-ke.mail.protection.outlook.com.
redcross.or.ke has HTTP service bindings 1 . alpn="h3,h2" ipv4hint=104.21.81.172,172.67.162.183 ech=AEX+DQBBKgAgACA9WtXji3GjMKpW33rouXuXtjFSeitEc6DSzffa6A5gVgAEAAEAQASY2xvdWRmbGFyZS1lY2guY29tAAA= ipv6hint=2606:4700:3032::ac43:a2b7,2606:4700:3033::6815:51ac
```

Figure 2: The Host utility resolved the target domain to its associated IP address.

DNS Information Lookup

```
(him@kali)-[~]  
$ nslookup redcross.or.ke  
Server:      192.168.100.1  
Address:     192.168.100.1#53  
  
Non-authoritative answer:  
Name:   redcross.or.ke  
Address: 104.21.81.172  
Name:   redcross.or.ke  
Address: 172.67.162.183  
Name:   redcross.or.ke  
Address: 2606:4700:3032::ac43:a2b7  
Name:   redcross.or.ke  
Address: 2606:4700:3033::6815:51ac
```

Figure 3: The NSLookup command retrieved DNS information for the target domain.

Email and Subdomain Enumeration

```
(him@kali)-[~]
$ theHarvester -d redcross.or.ke -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* theHarvester
*
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: redcross.or.ke
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.
```

Figure 4: TheHarvester performed passive reconnaissance but did not identify any publicly available emails or hosts.

Website Technology Identification

```
(him@kali)-[~]
$ whatweb https://redcross.or.ke
https://redcross.or.ke [200 OK] CloudFlare, Country[RESERVED][ZZ], Email[Team-2Artboard-58-copy-3@3x.png,client-logosArtboard-10@4x-80.jpg,client-logosArtboard-12@4x-80.jpg,client-logosArtboard-22@4x-80.jpg,client-logosArtboard-25@4x-80.jpg,client-logosArtboard-26@4x-80.jpg,client-logosArtboard-35@4x-80.jpg,client-logosArtboard-53@4x-80.jpg,client-logosArtboard-57@4x-80.jpg,client-logosArtboard-6@4x-80.jpg], Frame, HTML5, HTTPServer[cloudflare], IP[172.67.162.183], JQuery[3.7.1], MetaGenerator[Elementor 4.1.1; features: additional_custom_breakpoints; settings: css_print_method-internal, google_font-enabled, font_display-swap,Powered by Slider Revolution 6.7.40 - responsive, Mobile-Friendly Slider Plugin for WordPress with comfortable drag and drop in interface.,Redux 4.5.10,WooCommerce 10.7.0,WordPress 6.9.4], PHP[8.3.30], PoweredBy[Slider], Script[application/json,module,speculationrules,text/javascript], Title[Kenya Red Cross &#8211; Always There], UncommonHeaders[link,nel,x-litespeed-cache,report-to,platform,panel,content-security-policy,alt-svc,x-turbo-charged-by,cf-cache-status,cf-ray], WordPress[6.9.4], X-Powered-By[PHP/8.3.30]
```

Figure 5: WhatWeb identified technologies running on the target website.

Reflection

This week introduced me to information gathering techniques used during reconnaissance. By using WHOIS, NSLookup, TheHarvester, and WhatWeb, I learned how publicly available information can reveal valuable details about a target while emphasizing the importance of ethical and responsible data collection.

WEEK 2 – SCANNING AND ENUMERATION

Open Port Discovery

```
(him@kali)-[~]
$ nmap localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-08 23:09 +0300
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000060s latency).
Other addresses for localhost (not scanned): ::1
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
```

Figure 6: Nmap identified open ports and active services on the host machine

Service Version Detection

```
(him@kali)-[~]
$ sudo nmap -sV localhost
[sudo] password for him:
Sorry, try again.
[sudo] password for him:
Sorry, try again.
[sudo] password for him:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-08 23:13 +0300
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

Figure 7: Nmap detected service versions running on open ports.

Operating System Detection

```
(him@kali)-[~]
$ sudo nmap -O localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-08 23:14 +0300
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00029s latency).
Other addresses for localhost (not scanned): ::1
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 1.59 seconds
```

Figure 6: Nmap identified open ports and active services.

Figure 8: Nmap identified characteristics of the host operating system.

Vulnerability Assessment

```
(him@kali)-[~]
$ sudo nmap --script vuln localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-08 23:15 +0300
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000070s latency).
Other addresses for localhost (not scanned): ::1
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.26 seconds
```

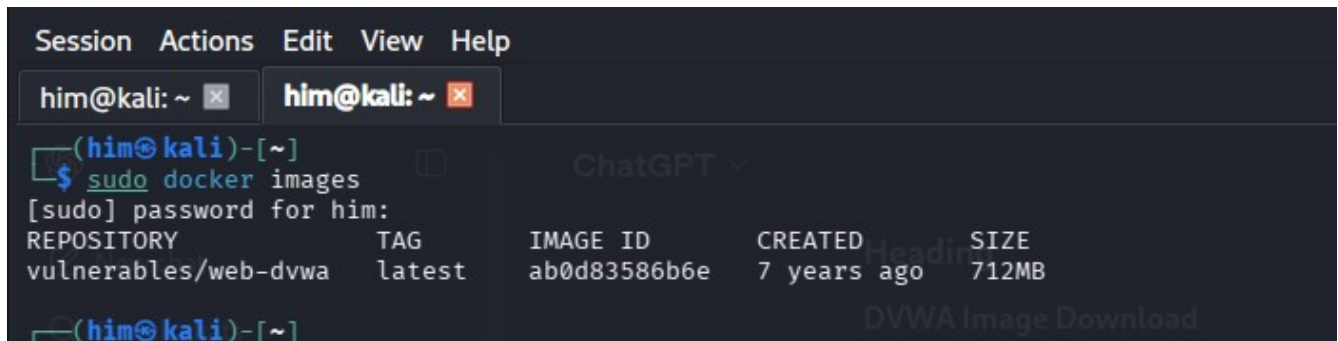
Figure 9: Nmap vulnerability scripts assessed the host for potential security weaknesses.

Reflection

This week improved my understanding of scanning and enumeration techniques. Using Nmap helped me identify open ports, services, operating system information, and potential vulnerabilities, demonstrating how attackers and defenders analyze a system's attack surface.

WEEK 3- Vulnerable Environment Setup

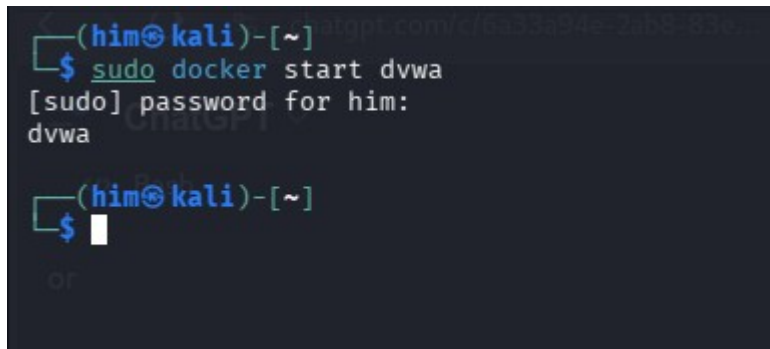
DOCKER INSTALLATION VERIFICATION

A terminal window with a dark background and light-colored text. The prompt is '(him@kali)-[~]'. The user enters '\$ sudo docker images'. The prompt changes to '[sudo] password for him:'. The user enters 'vulnerables/web-dvwa latest'. The terminal displays a table of Docker images. The table has five columns: REPOSITORY, TAG, IMAGE ID, CREATED, and SIZE. The first row shows 'vulnerables/web-dvwa', 'latest', 'ab0d83586b6e', '7 years ago', and '712MB'. The prompt returns to '(him@kali)-[~]'.

REPOSITORY	TAG	IMAGE ID	CREATED	SIZE
vulnerables/web-dvwa	latest	ab0d83586b6e	7 years ago	712MB

Figure 10: The DVWA Docker image was successfully downloaded and made available for deployment in the local testing environment.

DVWA Container

A terminal window with a dark background and light-colored text. The prompt is '(him@kali)-[~]'. The user enters '\$ sudo docker start dvwa'. The prompt changes to '[sudo] password for him:'. The user enters 'dvwa'. The prompt returns to '(him@kali)-[~]'. The user enters '\$' followed by a cursor.

```
(him@kali)-[~]  
$ sudo docker start dvwa  
[sudo] password for him:  
dvwa  
  
(him@kali)-[~]  
$
```

Figure 11: The DVWA container was started successfully and verified to be running in the Docker environment.

Reflection

This week enhanced my practical skills in preparing a secure testing environment. I learned how Docker containers can be used to deploy vulnerable applications safely for cybersecurity training and ethical hacking exercises.

WEEK 4 – Web Application Deployment and Configuration

DVWA Login Interface



The DVWA logo features the text "DVWA" in a bold, dark grey sans-serif font. To the right of the text is a stylized graphic consisting of two overlapping, curved lines. The top line is dark grey and the bottom line is a vibrant lime green, creating a sense of motion or a protective shield.

Username

Password

Login

Figure 12: The DVWA login page provides access to the vulnerable web application used for security testing.

DVWA Database Setup



Username

Password

Login

Figure 13: The DVWA database setup page was used to initialize and configure the application database.

DVWA Home Interface

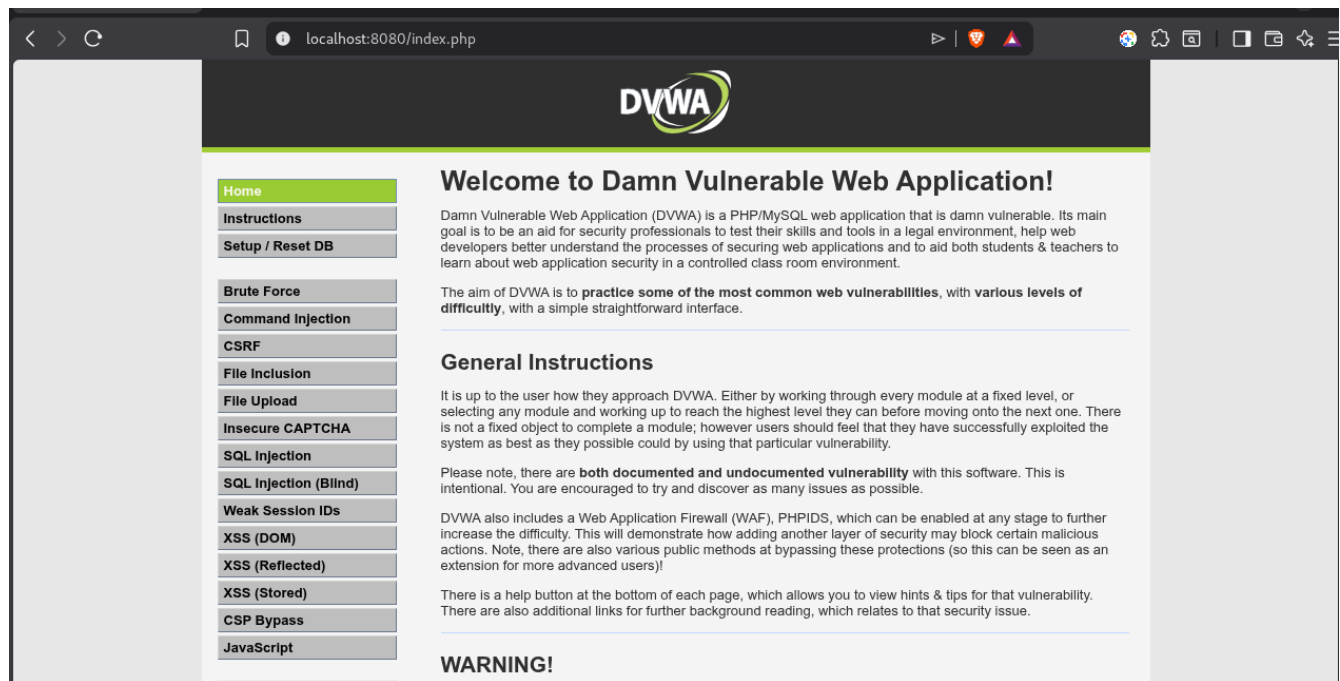


Figure 14: The DVWA home interface provided access to the various security testing modules available within the application.

Reflection

This week focused on configuring and accessing the DVWA platform. I learned how vulnerable web applications are deployed, initialized, and prepared for testing within a controlled environment.

Week 5 – SQL Injection Testing and Exploitation

SQL Injection Module



Figure 15: The SQL Injection module was accessed to evaluate input handling in a controlled testing environment.

SQL Injection Test Results

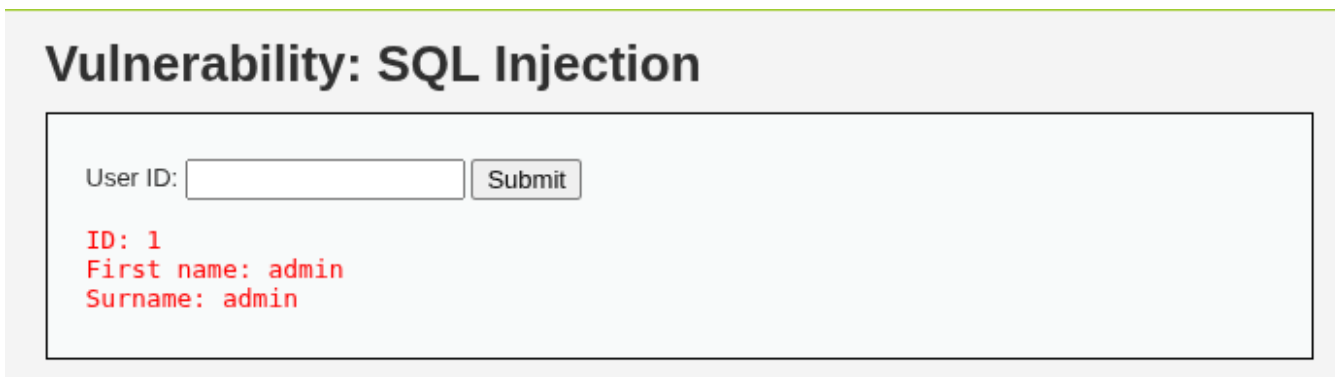
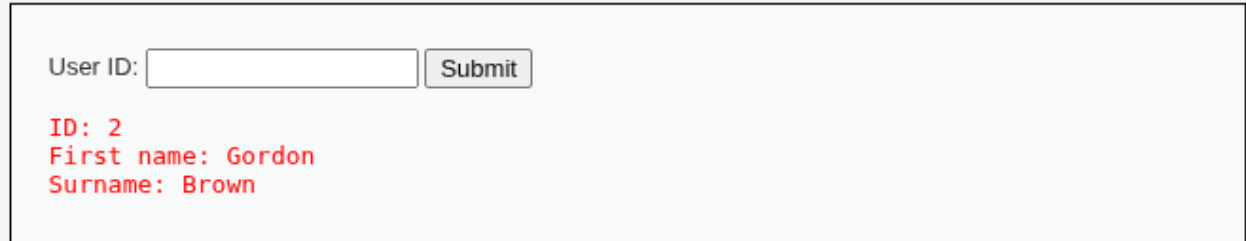


Figure 16: The application successfully processed the supplied User ID and returned database records from the backend.

Retrieval of Additional User Records

Vulnerability: SQL Injection



User ID:

ID: 2
First name: Gordon
Surname: Brown

Figure 17: The application retrieved a different user record based on the supplied User ID, confirming that database queries are driven by user input.

Reflection

This week provided hands-on experience with SQL Injection testing. It demonstrated how poor input validation can expose sensitive information and reinforced the importance of secure coding practices and parameterized database queries.

WEEK 6 – VULNERABILITY ASSESSMENT AND SCANNING

Nikto Installation

```
(him@kali)-[~]
$ sudo apt install nikto -y
nikto is already the newest version (1:2.6.0-0kali4).
nikto set to manually installed.
The following packages were automatically installed and are no longer required:
  enchant-2 libraw23t64 libxmlsec1-nss1
  libavc1394-0 libSDL2-classic libxmlsec1-openssl1
  libgdal38 libsimdutf31 postgresql-common-dev
  libio-pty-perl libsodium23 python3-pluginbase
  libipc-run-perl libteamctl0 python3-pysnmp4
  libmbcrypto16 libthrift-0.22.0 python3-tz
  libpostal-data libunibreak6
  libpostal1 libxmlsec1-1
Use 'sudo apt autoremove' to remove them.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 317
```

Figure 18: Nikto was successfully installed on the Kali Linux environment to support web server vulnerability assessment activities.

Web Server Vulnerability Scan Using Nikto

```
└─$ nikto -h http://localhost:8080
- Nikto v2.6.0

+ Target IP:      127.0.0.1
+ Target Hostname: localhost
+ Target Port:    8080
+ Platform:      Linux/Unix
+ Start Time:     2026-06-18 11:59:38 (GMT3)

+ Server: Apache/2.4.25 (Debian)
+ ERROR: Failed to check for updates: 403
+ [95] /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [95] /: Cookie security created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [750500] /config/: Directory indexing found.
+ [000998] /config/: Configuration information may be available remotely.
+ [750500] /docs/: Directory indexing found.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006333] /login.php: Admin login page/section found.
+ [007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 7799 requests: 16 errors and 16 items reported on the remote host
+ End Time:      2026-06-18 12:05:07 (GMT3) (329 seconds)

+ 1 host(s) tested
```

Figure 19: Nikto identified security issues and configuration weaknesses on the target web server.

Web Server Header Analysis

```
(him@kali)-[~]
$ curl -I http://localhost:8080
HTTP/1.1 302 Found
Date: Thu, 18 Jun 2026 09:19:18 GMT
Server: Apache/2.4.25 (Debian)
Set-Cookie: PHPSESSID=23r9tu8i4v3cq7ojj2j6mbjir0; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=23r9tu8i4v3cq7ojj2j6mbjir0; path=/
Set-Cookie: security=low
Location: login.php
Content-Type: text/html; charset=UTF-8
```

Figure 20: HTTP response headers were examined to identify security-related configuration information exposed by the web server

CVE Vulnerability Research

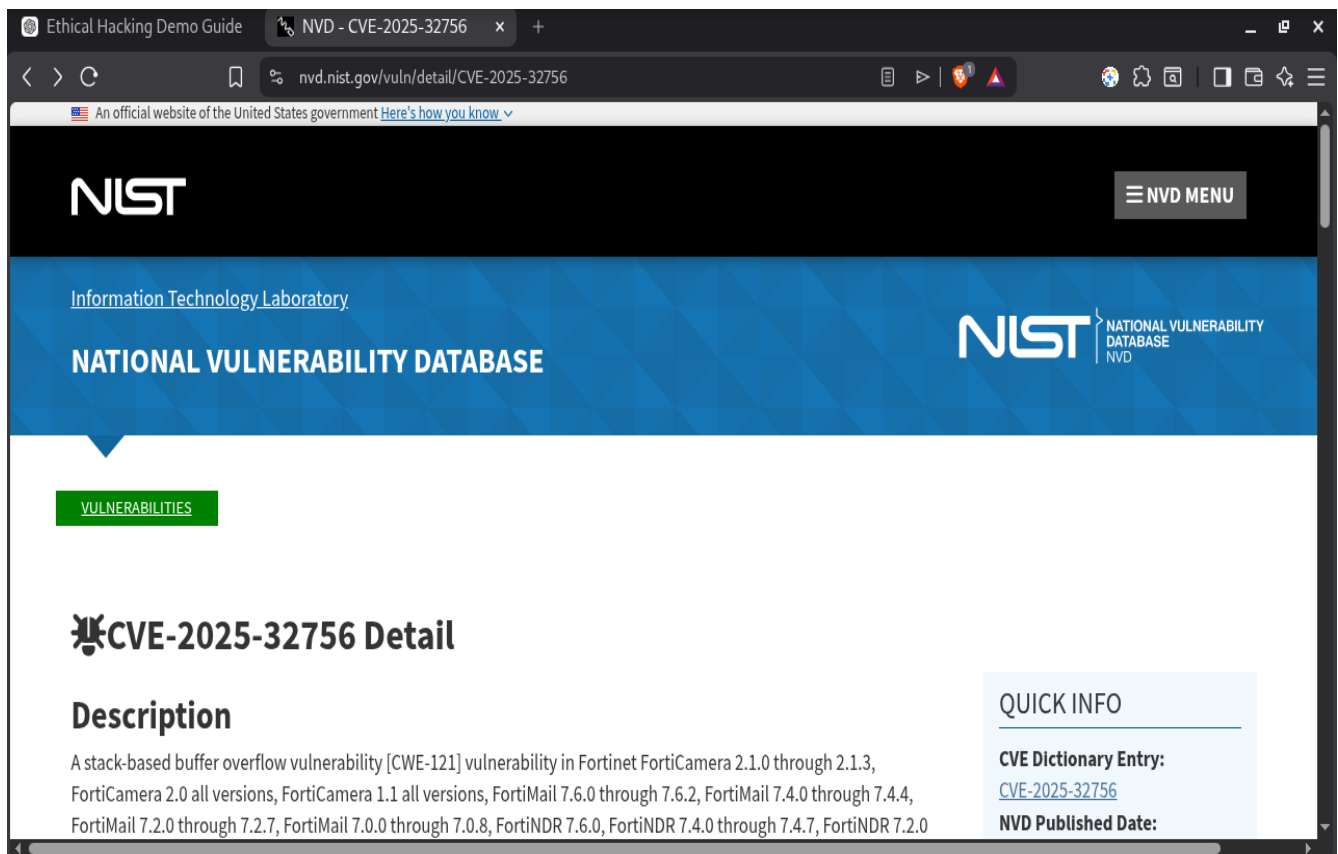


Figure 21: A recent CVE entry was examined to understand the nature and impact of a publicly disclosed vulnerability.

CVE Number

CVE-2025-32756

Description

A stack-based buffer overflow vulnerability affecting multiple Fortinet products.

Severity

High

Potential Impact

An attacker may exploit the vulnerability to execute arbitrary code or cause system compromise.

Mitigation

Apply vendor security updates and patches released by Fortinet.

Reflection

This week improved my understanding of vulnerability assessment and management. Through Nikto scanning, HTTP header analysis, and CVE research, I learned how security weaknesses are identified, analyzed, and mitigated to improve the overall security posture of systems and web applications.

WEEK 7

HTTP REQUEST ANALYSIS

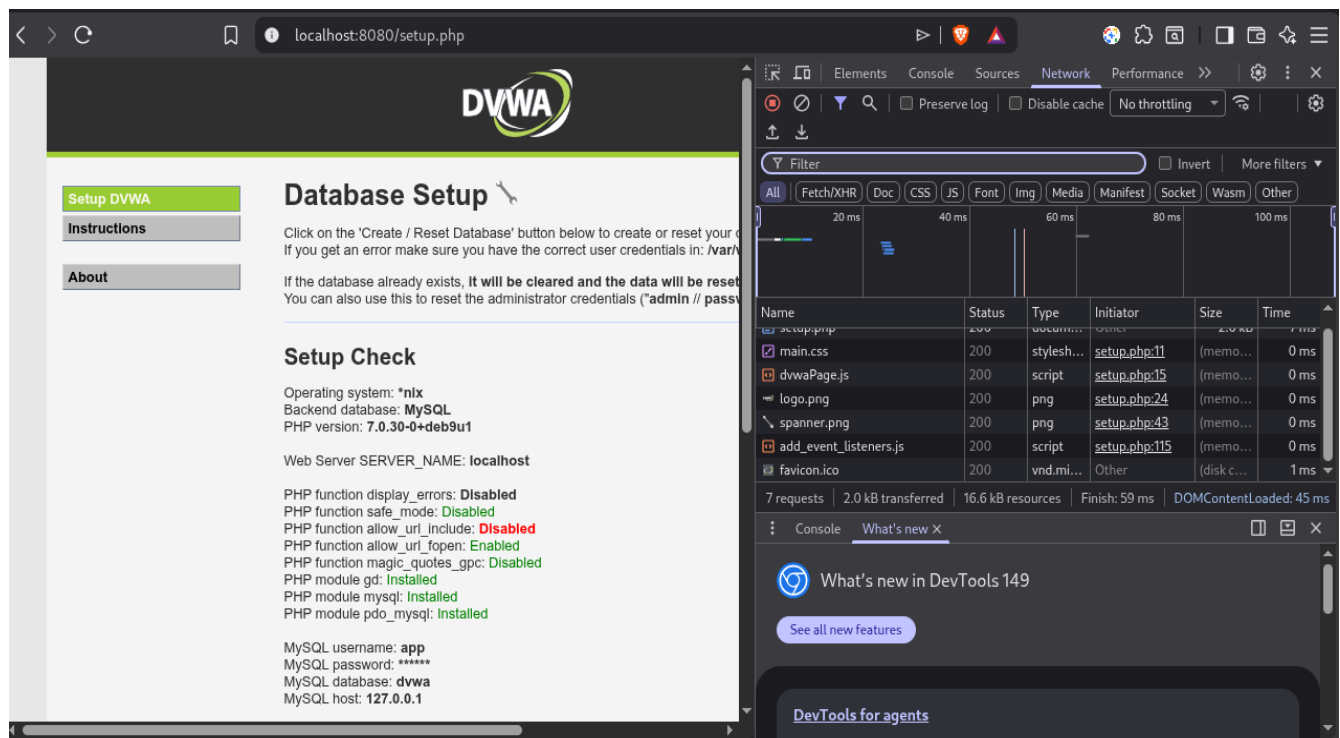


Figure 22: Browser developer tools were used to inspect HTTP requests and responses exchanged with the web application

Cookie Security Analysis

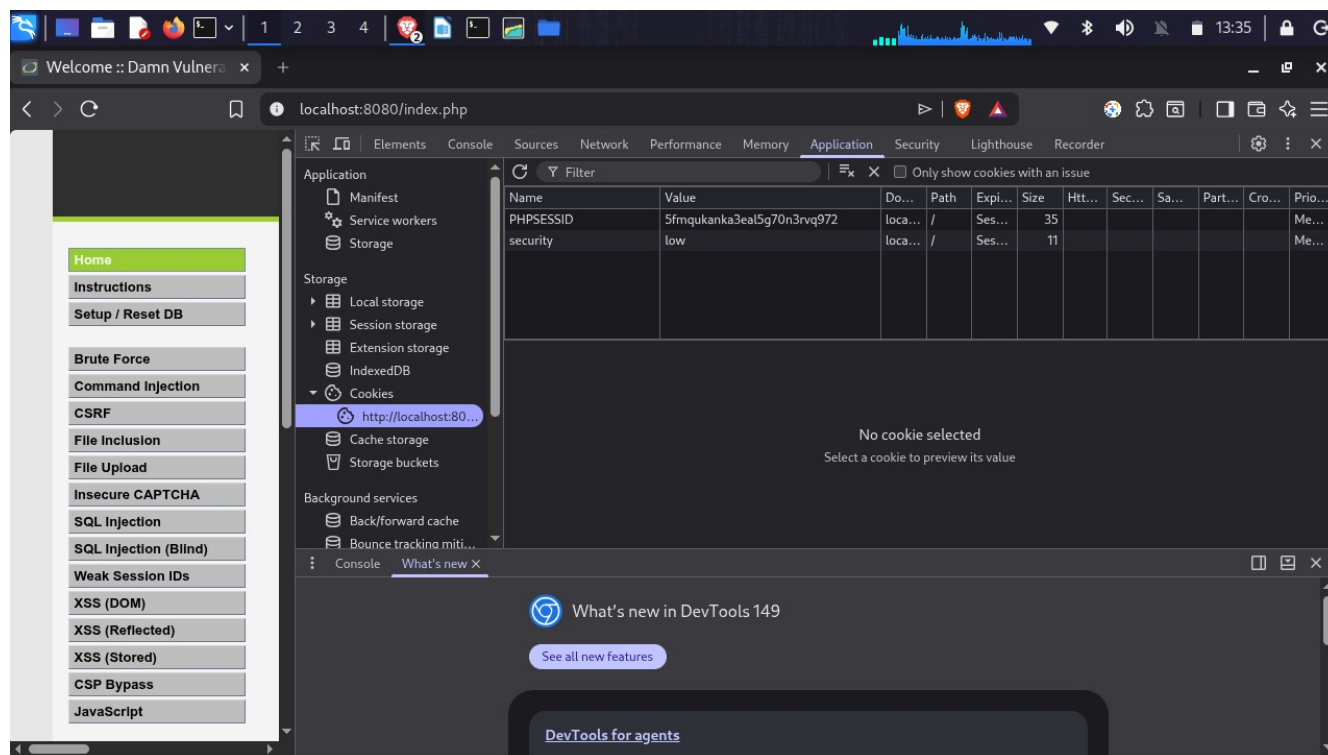


Figure 23: Session cookies were inspected to evaluate security-related attributes used in web application authentication.

Cross-Site Scripting Testing

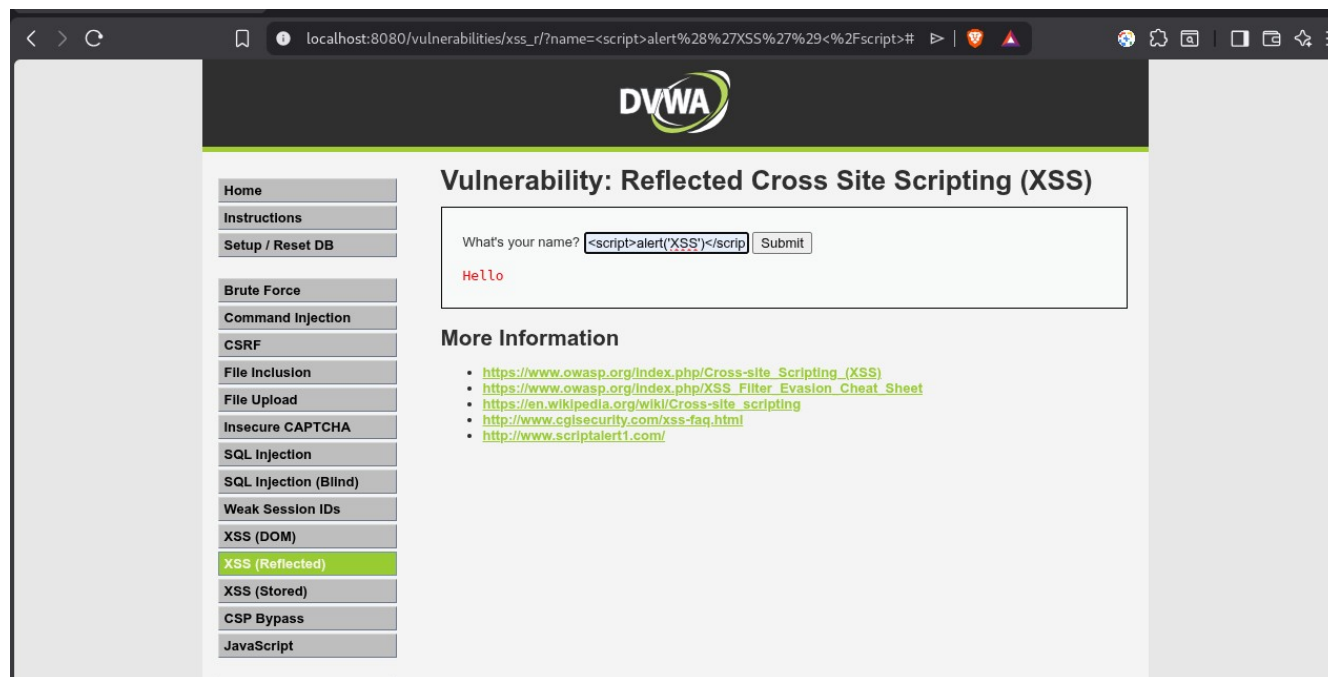


Figure 24: Reflected XSS testing demonstrated how improper input validation can allow script execution within a web application.

OWASP Top 10 Security Risks

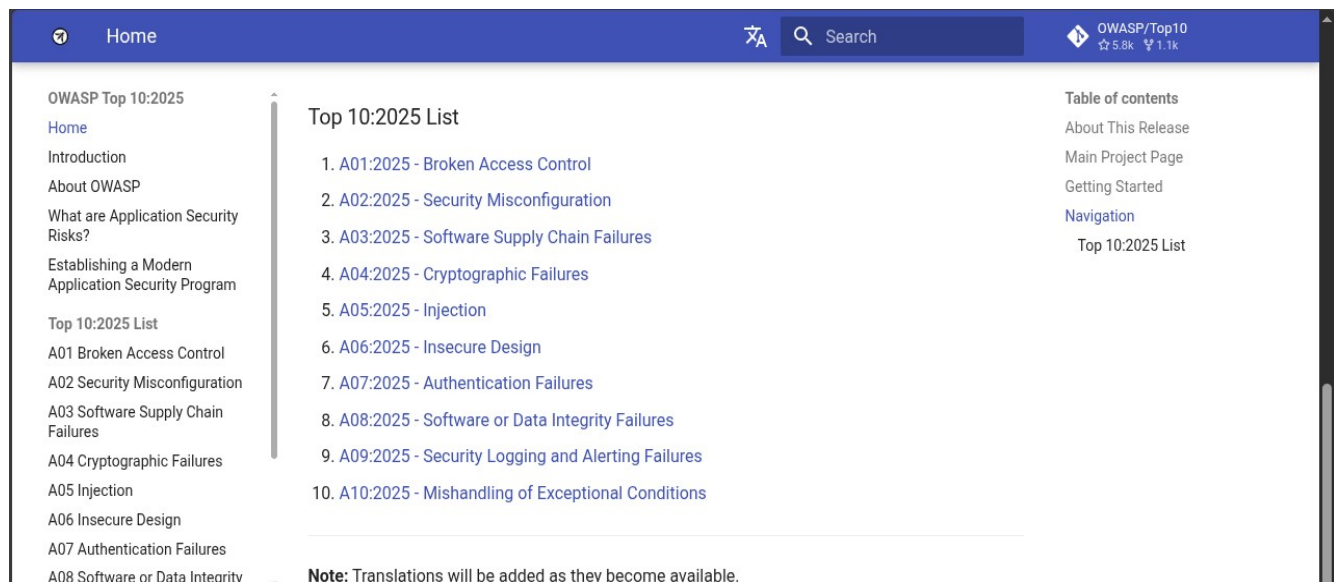


Figure 25: The OWASP Top 10 security risks were reviewed to understand common web application

Reflection

This week enhanced my understanding of web application security and common attack vectors. Through HTTP request analysis, cookie inspection, XSS testing, and OWASP Top 10 research, I learned how web vulnerabilities are identified and how security controls help protect applications from attacks.